

Privileged Account Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-SEC-PA-004

Version 1.0 | Effective: 18 Feb 2026

Document Control Page

Field	Details
Policy Title	Privileged Account Policy
Policy Number	FTAID-POL-SEC-PA-004
Author	Stanley Osuozah
Policy Owner	Chief Information Security Officer
Reviewer	IT Security Committee (Group 2)
Approver	Chief Executive Officer
Version	1.0
Effective Date	18 February 2026
Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organisational Controls / Technological Controls
ISO 27002:2022 Sub-domain	Access Control / Identity & Privileged Access Management
ISO 27002:2022 Control	5.15, 5.16, 5.18, 8.2, 8.15
Related Policies	Information Security Policy, Access Control Policy, Logging & Monitoring Policy
Approval Status	Pending Review

Approval Evidence

Approver: Chief Executive Officer

Signature: _____ Date: 18 Feb 2026

1. Purpose and Scope

Purpose:

This policy establishes controls for the creation, approval, monitoring, and secure use of privileged accounts to protect FortisAid's clinical systems, patient data, and cloud infrastructure from misuse or compromise.

Scope:

This policy applies to:

- All FortisAid employees, clinicians, contractors, vendors, and third parties
- All systems, including EHR platforms, remote patient monitoring (RPM), cloud services, databases, and network infrastructure
- All accounts with administrative, root, system-level, or elevated privileges

FortisAid Context:

FortisAid delivers digital healthcare services using cloud-hosted electronic health records, remote patient monitoring platforms, and clinical analytics systems that process and store sensitive patient health information.

2. ISO 27002:2022 Alignment

ISO Domain	ISO Sub-domain	Control Number	How this policy address it
Organisational Controls	Access Control	5.15	Defines rules restricting privileged access to authorised users only
Organisational Controls	Identity Management	5.16	Requires controlled lifecycle management of privileged identities
Organisational Controls	Access Rights	5.18	Mandates approval, review, and removal of privileged rights
Technological Controls	Privileged Access Rights	8.2	Establishes strict assignment, monitoring, and logging of admin accounts

Technological Controls	Logging and Monitoring	8.15	Requires logging and review of privileged account activities
-------------------------------	------------------------	------	--

3. Threats and Key Risks (Healthcare

Context) Threats:

- Compromise of administrator credentials via phishing or malware
- Insider misuse of elevated privileges
- Unmonitored service accounts or shared admin passwords

Key Risks to FortisAid:

- Breach of patient health information (PHI)
- Disruption of clinical systems affecting patient safety
- Regulatory penalties under UK GDPR

4. Policy Statements / Requirements

4.1 Privileged Account Assignment

1. Privileged access shall be granted only when necessary, in accordance with least-privilege principles.
2. All privileged accounts must be individually assigned; shared administrative accounts are prohibited unless technically unavoidable and formally approved.
3. Requests for privileged access must include:
 - Business justification
 - System owner approval
 - Information Security approval

4.2 Secure Use of Privileged Accounts

1. Privileged accounts must be used only for administrative tasks, not for routine work such as email or browsing.
2. Multi-factor authentication (MFA) is mandatory for all privileged access to FortisAid systems.
3. Privileged sessions must be:
 - Logged
 - Time-limited where possible
 - Conducted via secure management workstations or privileged access management (PAM) tools

4. Default vendor or system administrator passwords must be changed immediately upon deployment.

4.3 Monitoring, Review, and Removal

1. All privileged account activity shall be logged and monitored for suspicious behaviour.
2. The IAM or Security team shall conduct quarterly reviews of privileged accounts to verify:
 - Continued business need
 - Correct privilege level
 - Account ownership
3. Privileged access must be revoked immediately when:
 - A staff member changes role
 - A contractor engagement ends
 - An account is suspected of being compromised
4. Dormant privileged accounts inactive for 30 days must be automatically disabled unless justified.

5. Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer	Final approval and organisational support
Chief Information Security Officer	Policy ownership, enforcement, and compliance oversight
IT Security / IAM Team	Provisioning, monitoring, logging, and review of privileged accounts
System Owners	Approve and validate business justification for privileged access
Clinical Systems Director	Ensure privileged access does not compromise clinical safety
All Staff with Privileged Access	Use access responsibly and report any misuse or suspected compromise immediately

6. Compliance and Enforcement Monitoring

Activities:

- Quarterly privileged access reviews conducted by IT Security
- Continuous logging of administrative actions in SIEM or monitoring systems
- Evidence stored in FortisAid's secure audit repository

Non-Compliance:

Violations may result in disciplinary action, up to and including termination, and may be reported to regulatory authorities where required.

Exceptions:

Violations of this policy may result in disciplinary action, suspension of system access, termination of employment or contract, and reporting to regulators where required.

7. Training and Awareness

- Mandatory privileged-access security training within 30 days of assignment
- Annual refresher training for all privileged users
- Additional secure-administration training for system administrators and cloud engineers

8. Review and Revision

This policy will be reviewed annually or following:

- Security incidents involving privileged accounts
- Changes to UK healthcare security requirements
- Major infrastructure or cloud platform changes

Next scheduled review: **18 February 2027.**

References

- ISO/IEC 27002:2022
- UK GDPR / Data Protection Act 2018
- NHS Data Security and Protection Toolkit
- HIPAA Security Rule

References

- ISO/IEC 27002:2022
- UK GDPR / Data Protection Act 2018
- HIPAA Security Rule
- NHS Data Security and Protection Toolkit
- FortisAid Governance Structure

Appendix A: Approval Record

text

Policy Approval Email:

From: CEO@fortisaid.com

To: CISO@fortisaid.com

Subject: APPROVAL: Information Security Policy v1.0

Date: 18 February 2026